



CIBERSEGURIDAD EN ENTORNOS DE LAS TECNOLOGÍAS DE LA INFORMACIÓN

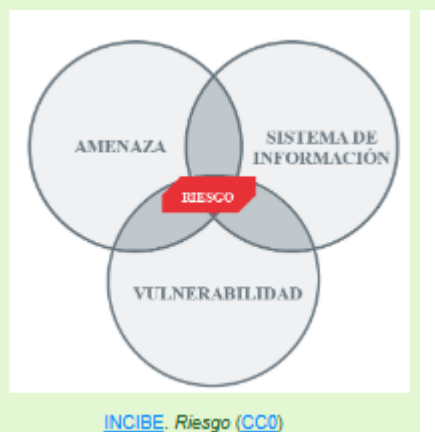
Incidentes de Ciberseguridad

TEMA 2

Auditoría de Incidentes de Ciberseguridad.
Alberto Diéguez Álvarez

Descripción de la tarea.	3
 Clasificación de riesgos y potenciales incidentes.....	3
Introducción: Diagrama de bloques y detalles de activos de la empresa... 	4
Apartado 1: Priorización y jerarquía de activos.	5
Apartado 2: Valoración de los dominios de seguridad.....	9
Apartado 3: Determinación de las amenazas y sus salvaguardas dispuestas.....	11
Apartado 4: Estimación del riesgo que tendría que considerar la empresa para su estudio y toma de decisiones.....	14
Apartado 5: Taxonomía de incidentes.....	18

Clasificación de riesgos y potenciales incidentes.



Un Sistema de Gestión de Seguridad de la Información debe disponer de un correcto sistema de gestión de riesgos.

Un proceso de gestión de riesgos de seguridad de la información trata de identificar, comprender, evaluar y mitigar los riesgos.

El concepto de riesgo se corresponde con la probabilidad de que se produzca un incidente de seguridad, materializándose una amenaza y

causando pérdidas o daños. El riesgo depende entonces de los siguientes factores: la probabilidad de que la amenaza se materialice aprovechando una vulnerabilidad y produciendo un daño o impacto. El producto de estos factores representa el riesgo.

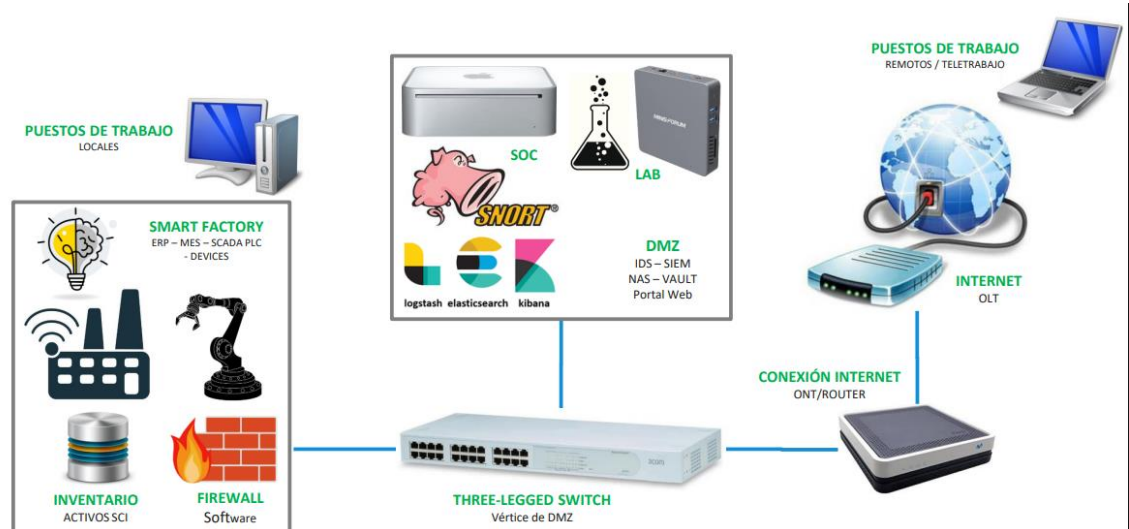
En esta tarea realizaremos un análisis y gestión de riesgos en la empresa ficticia de la unidad anterior para evitar o disminuir la probabilidad de que se produzcan diversos incidentes. Para este análisis seguiremos la metodología [MAGERIT v.3](#) desarrollada por el gobierno español.

Además, haremos uso de la herramienta [PILAR \(versión Basic\)](#) que implementa la metodología MAGERIT que ha sido desarrollada por el Centro Criptológico Nacional (CCN). Este software es privativo y debe licenciarse, pero provee de una licencia de evaluación de 30 días, que es la que usaremos en este caso práctico.

¿Qué te pedimos que hagas?

Introducción: Diagrama de bloques y detalles de activos de la empresa.

La empresa tiene el siguiente diagrama de bloques:



La empresa tiene los siguientes activos materiales principales:

Activo	Dirección IP	Sistema Operativo	Modelo Máquina	Función Empresa
Router	192.168.1.1	Askey SO	RTF3505VW	Router conexión Internet
Switch	192.168.1.11	3COM SO	SuperStack 3 3300XM	Three-Legged Switch
SOC	192.168.1.101	MacOS Ventura	Mac Mini M1	IDS/SIEM/NAS/VAULT
Labo Server	192.168.1.102	Debian 11	MinisForum HM90	Servidor Laboratorio
ERP	192.168.1.25	Debian 11	ProLiant uServer Intel Xeon E	Servidor Gestor Empresarial
MES	192.168.1.24	Raspbian	Raspberry Pi 4B	Servidor Gestor Factoría
SCADA	192.168.1.23	Raspbian	Raspberry Pi 4B	Supervisión / Control / Firewall / Inventario
PLC	192.168.1.22	Raspbian	Raspberry Pi 4B	Controlador lógico
DEVICE	192.168.1.21	Raspbian	Raspberry Pi 4B	Dispositivo fabril
B.D. Inventario	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos de Inventario
B.D. ECO/FIN	192.168.1.25	MacOS Ventura	Mac Mini M1	Base de datos ECO / FIN
Puestos trabajo	192.168.1.50-99	Windows 11 Pro	Lenovo ThinkCentre M720t	Puestos de trabajo
Maquetas, Prototipos	192.168.1.102	Debian 11	MinisForum HM90	Maquetas, prototipos, lanzaderas
Portal Web	192.168.1.102	Debian 11	MinisForum HM90	Portales web
Big Data, IA	192.168.1.50-99	Windows 11	Lenovo ThinkCentre M720t	Sistemas Big Data, IA

Nota: Todos los datos no proporcionados de la empresa deben ser definidos de forma autónoma y libre como si fueras parte de la dirección general de la empresa, justificando su elección. Por ejemplo: se puede decidir si los equipos actualmente disponen de una política de contraseñas seguras o si por el contrario no existen políticas al respecto. En cualquiera de los casos, debe exponerse en el documento de prácticas.

Apartado 1: Priorización y jerarquía de activos.

Deberás efectuar la siguiente tarea:

- A partir de la lista de activos de la introducción, se deben priorizar y jerarquizar indicando los que crees que son esenciales para la empresa. Se ordenan desde el de más importancia al de menor, además se deben indicar aquellos que dependen de otros.

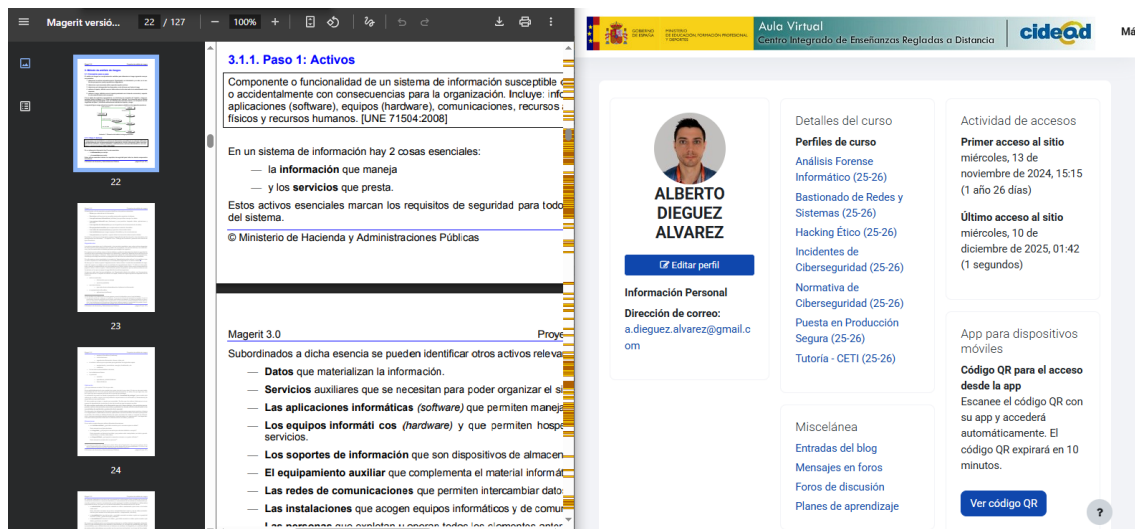
De la anterior lista de activos, se debe seleccionar uno por cada uno de estos tipos indicados: activo esencial de información, activo esencial de servicio, activo de equipamiento informático y un activo de redes de comunicación.

Con el uso de la herramienta PILAR se debe recoger la información de los cuatro activos anteriores.

Estos activos deben definirse en su capa correcta y en un dominio de seguridad adecuado, por lo que habrá que crear los dominios de seguridad necesarios.

Muestra la ventana detallada de información de estos cuatro activos.

Reviso MAGERIT 3.0



Después de leer y buscar por los libros, y por la web, creo que lo más acertado sería:

1. **Router:** Es el motor de comunicación a internet.
2. **Switch:** Conecta múltiples activos en una red local, sin ellos los equipos no se comunicarían entre sí.
3. **SCADA:** Controla y monitorea la seguridad de la fábrica.
 - a. Depende del Switch para estar conectado con el resto de equipos.
4. **PLC:** Ejecuta las acciones.
 - a. Depende de SCADA para recibir instrucciones.
5. **B.D. ECO/FIN:** Es la base de datos del negocio.
6. **B.D. Inventario.**

- a. Depende del Switch para estar conectado con el resto de equipos.
7. **ERP:** Gestiona los procesos como pedidos, facturación...
 - a. Depende de B.D. ECO/FIN que es la base de datos que contiene la información.
8. **SOC:** Monitoriza la seguridad.
 - a. Depende del Switch para estar conectado con el resto de equipos.
9. **MES:** Es un software para controlar la producción.
 - a. Depende de ERP que es la BBDD que contiene la información.
10. **Puestos de trabajo:** Son las máquinas que usan los trabajadores.
 - a. Dependen de Switch para estar conectadas entre ellas, del ERP ya que gestiona los procesos como pedidos, y por último diría el ROUTER para tener conexión a internet.
11. **Labo_Server.**
12. **DEVICE.**
13. **MAQUESTAS, PROTOTIPO.**
14. **PORTAL WEB.**
15. **BIG DATA, IA.**

Me descargo e instalo PILAR.

The image displays two screenshots from a web application. The left screenshot shows the 'EAR / PILAR Basic' download page. It features a sidebar menu with categories like 'PILAR', 'PILAR Basic', 'PILAR RM', 'PILAR BCM', and 'PILAR'. The main content area is titled 'EAR / PILAR Basic descarga' and includes a note about the license. Below this, there's a section for 'PILAR Basic 2025.1.4 (31.10.2025)' with a list of download links for different operating systems (Windows, Linux, Mac) and instructions. The right screenshot shows the 'Aula Virtual' user profile page for Alberto Dieguez Alvarez. It includes a user profile card with a photo and name, a section for 'Información Personal' with email and phone number, and several panels for course details, activity logs, and QR codes for mobile app access.

Creo el proyecto de la empresa ficticia.

The screenshot shows the Pylar Basic application interface. A 'Nuevo proyecto' dialog box is open, displaying a table with project details. The table has columns for 'código', 'nombre', 'valor', 'desc', 'autor', 'versión', 'fecha', 'owner', and 'cisoA'. The 'nombre' field is set to 'Reservas empresa'. The 'proyecto - clasificación' dropdown is set to 'RESERVADO'. The 'contexto' dropdown is set to 'RGPD'. The 'owner' field is set to 'Alberto Dieguez Álvarez'. The 'cisoA' field is set to 'Alberto Dieguez Álvarez'. The dialog box also has buttons for 'descripción', 'arriba', 'abajo', 'nueva', 'eliminar', 'estándar', and 'limpiar'.

código	nombre	valor	desc	autor	versión	fecha	owner	cisoA
[std]	Biblioteca INFOSEC (22.7.2023) (std_20251.pls)							
2025AD	Reservas empresa						Alberto Dieguez Álvarez	Alberto Dieguez Álvarez

Añado los dominios.

The screenshot shows the Pylar Basic application interface. A 'Dominios de seguridad' dialog box is open, displaying a tree view of security domains. The tree view has a root node 'Dominios de seguridad' with several sub-nodes: '(base) Red de empresa', '(Información) activo esencial de información', '(Servicio) activo esencial de servicio', '(Equipo) activo de equipamiento informático', and '(Comunicación) activo de redes de comunicación'. The dialog box also has buttons for 'TSV', 'descarga', 'adquisición', and 'documentación'.

Además de descargar el material que se relaciona a continuación, se

Dominios de seguridad

- (base) Red de empresa
- (Información) activo esencial de información
- (Servicio) activo esencial de servicio
- (Equipo) activo de equipamiento informático
- (Comunicación) activo de redes de comunicación

TSV

- mac: instrucciones
- IT
 - windows: [descarga] [firma]
 - linux: [descarga] [firma]
 - mac: instrucciones

Dejo el tratamiento de riesgos por defecto.

The screenshot shows a web application interface for a course titled "EAR / PILAR Basic". The interface includes a sidebar with navigation links for "EAR", "PILAR", "PILAR Basic", "PILAR RM", "PILAR BCM", and "RMAT". The main content area displays the course title and a "descarga" (download) button. A download window is open, showing a list of documents for "[2025AD] Tratamiento de los riesgos (opciones)". The window lists various documents with checkboxes for "visible", "aplicar", and "ignorar". The documents include:

- PILAR - Salvaguardas propias
- NIST SP800-53 - Security and Privacy Controls for Information Systems and Organizations
- [7002:2022] Control de la seguridad de la información
- [27701:2019] Extensión de las Normas ISO/IEC 27001 e ISO/IEC 27002 para la gestión de provacidad de la información
- [7002:2013] Código de prácticas para los controles de seguridad de la información

The download window also shows a list of files for "IT" (Information Technology) with checkboxes for "descarga" (download) and "firma" (signature). The files include:

- mac: instrucciones
- windows: [descarga] [firma]
- linux: [descarga] [firma]
- mac: instrucciones

The background interface shows a user profile for "ALBERTO DIEGUEZ ALVAREZ" and a list of course details, including "Perfiles de curso" (Course Profiles) and "Informes" (Reports).

Genero las fases del proyecto actual y objetivo.

The screenshot shows a web application interface for a course titled "EAR / PILAR Basic". The interface includes a sidebar with navigation links for "EAR", "PILAR", "PILAR Basic", "PILAR RM", "PILAR BCM", and "RMAT". The main content area displays the course title and a "descarga" (download) button. A download window is open, showing a list of documents for "[2025AD] Fases del proyecto". The window lists various documents with checkboxes for "visible", "aplicar", and "ignorar". The documents include:

- [current] situación actual (I)
- [target] situación objetivo (I)

The download window also shows a list of files for "IT" (Information Technology) with checkboxes for "descarga" (download) and "firma" (signature). The files include:

- mac: instrucciones
- windows: [descarga] [firma]
- linux: [descarga] [firma]
- mac: instrucciones

The background interface shows a user profile for "ALBERTO DIEGUEZ ALVAREZ" and a list of course details, including "Perfiles de curso" (Course Profiles) and "Informes" (Reports).

Identifico los activos según mi criterio. Y lo muestro en estadísticas por capa y por dominios.

Examen Presencial (por capas)

capa	essential	archi	qualifier	ISI	keys	ISI	SW	COM	Media	AUX	LI	PI	other	total
B	2	0	0	1	0	1	0	0	0	0	0	0	0	2
IS	0	0	0	0	0	0	0	0	0	0	0	0	0	0
E	2	0	0	0	1	0	1	0	0	0	0	0	0	2
SS	0	0	0	0	0	0	0	0	0	0	0	0	0	0
LI	0	0	0	0	0	0	0	0	0	0	0	0	0	0
P	0	0	0	0	0	0	0	0	0	0	0	0	0	0
TOTAL	4	0	0	1	0	2	0	1	0	0	0	0	0	4

por dominios

dominio de seguridad	essential	archi	qualifier	ISI	keys	ISI	SW	COM	Media	AUX	LI	PI	other	total
(base) Red de empresa	0	0	0	0	0	0	0	0	0	0	0	0	0	0
(información) activo esencial de información	1	0	0	1	0	0	0	0	0	0	0	0	0	1
(servicio) activo esencial de servicio	1	0	0	0	0	1	0	0	0	0	0	0	0	1
(equipamiento) activo de equipamiento informático	1	0	0	0	0	0	1	0	0	0	0	0	0	1
(comunicación) activo de redes de comunicación	1	0	0	0	0	1	0	0	0	0	0	0	0	1
TOTAL	4	0	0	1	0	2	0	1	0	0	0	0	0	4

Activos

- (B) Activos esenciales
 - (B01) Base de datos inventario
 - (ERP) Enterprise Resource Planning
 - (S) Servicios internos
 - (E) Equipamiento
 - (SW) Aplicaciones
 - (HW) Equipos
 - (Equipos) Puesto de trabajo
 - (COM) Comunicaciones
 - (Comunicación) Router
 - (AUX) Elementos auxiliares
 - (SS) Servicios subcontratados
 - (LI) Instalaciones
 - (PI) Personal

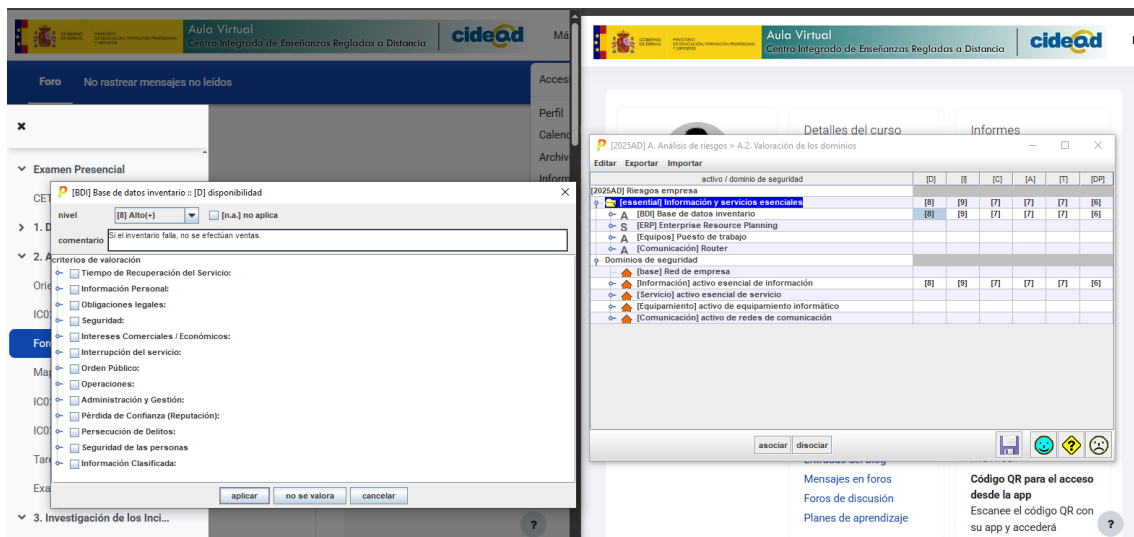
Apartado 2: Valoración de los dominios de seguridad.

Deberás efectuar la siguiente tarea:

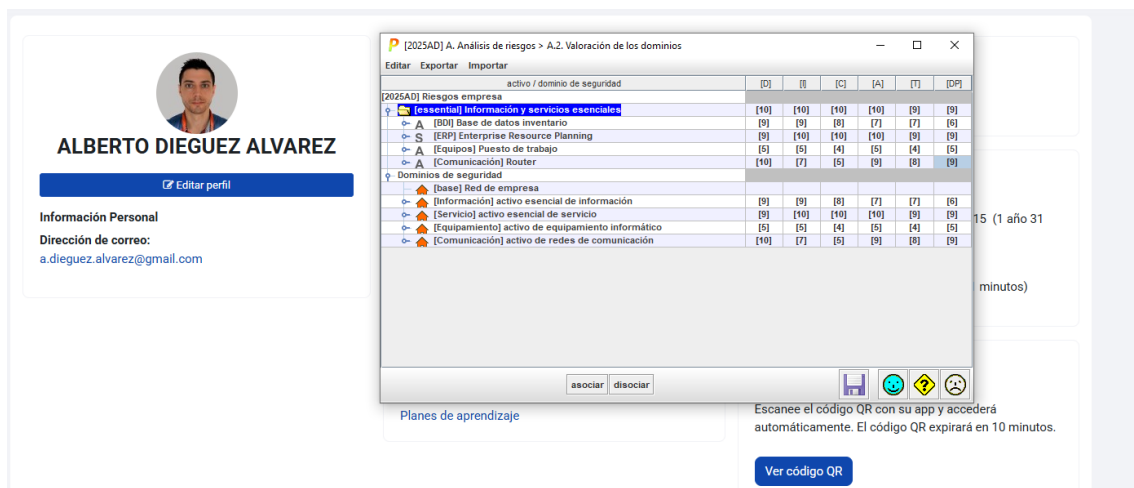
- Debes determinar el nivel de importancia que tienen los activos esenciales en sus diferentes dominios de seguridad definidos. Muestra una captura de pantalla con la valoración numérica de los activos en sus dominios de seguridad. Además, debes indicar, al menos, un par de factores atenuantes y/o agravantes por cada dominio de seguridad. Muestra una captura de estos factores.

Hago la valoración numérica de los activos en sus dominios de seguridad.

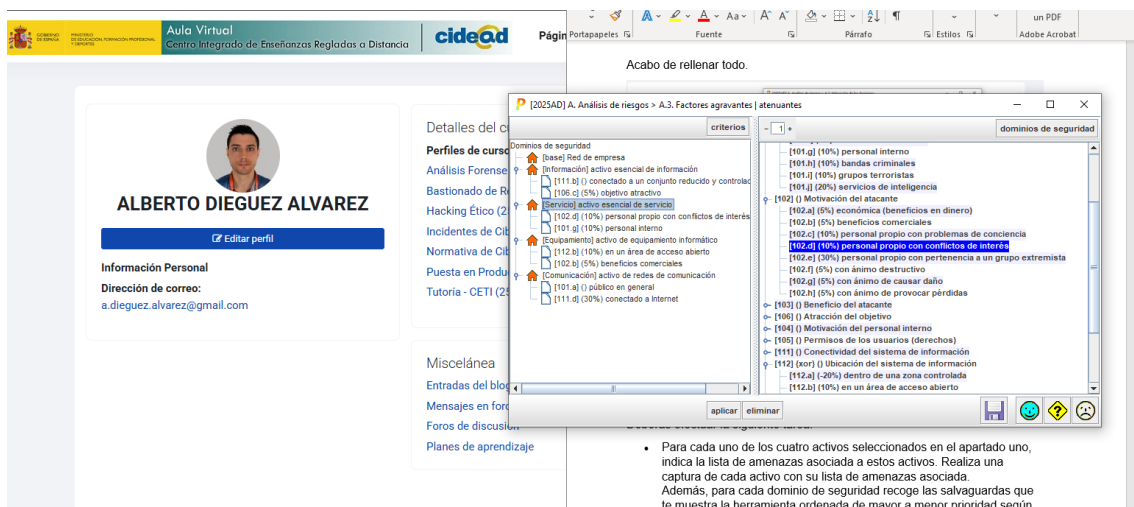
Voy rellenando y poniendo comentarios sobre las valoraciones.



Acabo de rellenar todo.



Aplico los atenuantes o agravantes.



Apartado 3: Determinación de las amenazas y sus salvaguardas dispuestas.

Deberás efectuar la siguiente tarea:

- Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la lista de amenazas asociada a estos activos. Realiza una captura de cada activo con su lista de amenazas asociada. Además, para cada dominio de seguridad recoge las salvaguardas que te muestra la herramienta ordenada de mayor a menor prioridad según la herramienta. Para cada una de estas salvaguardas debes indicar una acción concreta que se puede realizar para llevarla a cabo en cierto grado. Incluye también el estado actual y el estado objetivo de esta salvaguarda. Por último realiza una captura de pantalla en la que se ve muestren estas salvaguardas configuradas.

Accedo a amenazas.

The screenshot displays the CIDEAD platform interface. On the left, a tree view shows the hierarchy of threats, categorized by assets (Activos) and domains (Dominios). The right pane shows a detailed list of threats, including their descriptions and associated assets. The top navigation bar includes the user's name 'ALBERTO DIEGUEZ ALVAREZ' and the platform name 'CIDEAD'.

Activos:

- [B] Base de datos inventario
 - [E.15] Alteración de la información
 - [E.16] Destrucción de la información
 - [E.19] Fugas de información
 - [A.5] Suplantación de la identidad
 - [A.6] Abuso de privilegios de acceso
 - [A.11] Acceso no autorizado
 - [A.13] Repudio (negación de actuaciones)
- [S] ERP Enterprise Resource Planning
 - [E.1] Errores de los usuarios
 - [E.2] Errores del administrador del sistema
 - [E.10] Alteración de la información
 - [E.18] Destrucción de la información
 - [E.19] Fugas de información
 - [E.24] Caída del sistema por agotamiento
 - [A.5] Suplantación de la identidad
 - [A.6] Abuso de privilegios de acceso
 - [A.7] Uso no previsto
 - [A.11] Acceso no autorizado
 - [A.13] Repudio (negación de actuaciones)
 - [A.16] Modificación de la información
 - [A.18] Destrucción de la información
 - [A.24] Denegación de servicio
- [S] Servicios internos
- [E] Equipamiento
- [SW] Aplicaciones
- [HW] Equipos
 - [E.1] Errores de los usuarios
 - [E.2] Errores del administrador del sistema / de la seguridad
 - [E.3] Errores de monitorización (log)
 - [E.4] Errores de configuración
 - [E.7] Deficiencias en la organización
 - [E.8] Difusión de software dañino
 - [E.9] Errores de re-enclavamiento
 - [E.10] Errores de secuencia
 - [E.14] Fugas de información (> E.19)
 - [E.15] Alteración de la información
 - [E.16] Destrucción de la información
 - [E.19] Fugas de información
 - [E.20] Vulnerabilidades de los programas (software)
 - [E.21] Errores de mantenimiento / actualización de programas (software)
 - [E.22] Errores de mantenimiento / actualización de equipos (hardware)
 - [E.24] Caída del sistema por agotamiento de recursos
 - [E.25] Pérdida de equipos
 - [E.26] Indisponibilidad del personal
 - [E.28] Ataques deliberados
 - [P9] Riesgos sobre la privacidad

Amenazas:

- [N] Desastres naturales
 - [B.1] Fuego
 - [B.2] Daños por agua
 - [B.3] Desastres industriales
 - [B.3] Contaminación medioambiental
 - [B.4] Contaminación electromagnética
 - [B.5] Avería de origen físico o lógico
 - [B.6] Corte del suministro eléctrico
 - [B.7] Condiciones inadecuadas de temperatura o humedad
 - [B.8] Fallo de servicios de comunicaciones
 - [B.9] Interrupción de otros servicios o suministros esenciales
 - [B.10] Degradación de los soportes de almacenamiento de la información
 - [B.11] Emanaciones electromagnéticas (TEMPEST)
- [E] Errores y fallos no intencionados
 - [E.1] Errores de los usuarios
 - [E.2] Errores del administrador del sistema / de la seguridad
 - [E.3] Errores de monitorización (log)
 - [E.4] Errores de configuración
 - [E.7] Deficiencias en la organización
 - [E.8] Difusión de software dañino
 - [E.9] Errores de re-enclavamiento
 - [E.10] Errores de secuencia
 - [E.14] Fugas de información (> E.19)
 - [E.15] Alteración de la información
 - [E.16] Destrucción de la información
 - [E.19] Fugas de información
 - [E.20] Vulnerabilidades de los programas (software)
 - [E.21] Errores de mantenimiento / actualización de programas (software)
 - [E.22] Errores de mantenimiento / actualización de equipos (hardware)
 - [E.24] Caída del sistema por agotamiento de recursos
 - [E.25] Pérdida de equipos
 - [E.26] Indisponibilidad del personal
 - [E.28] Ataques deliberados
 - [P9] Riesgos sobre la privacidad

La lista continúa.

amenazas

- [-] 15) Modificación de la información
- [-] 16) Destrucción de la información
- [-] 24) Denegación de servicio
- [+] Servicios internos
- [+] Equipamiento
- [+] Aplicaciones
- [+] Equipos
- [+] [Equipos] Puesto de trabajo
 - [-] 1) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres naturales
 - [-] 15) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres industriales
 - [-] 13) Contaminación medioambiental
 - [-] 14) Contaminación electromagnética
 - [-] 5) Avería de origen físico o lógico
 - [-] 6) Corte del suministro eléctrico
 - [-] 7) Condiciones inadecuadas de temperatura o humedad
 - [-] 8) Fallos de servicios de comunicaciones
 - [-] 9) Interrupción de otros servicios o suministros esenciales
 - [-] 10) Degradación de los soportes de almacenamiento de la información
 - [-] 11) Emisiones electromagnéticas (TEMPEST)
- [+] Errores y fallos no intencionados
 - [-] 1) Errores de los usuarios
 - [-] 2) Errores del administrador del sistema / de la seguridad
 - [-] 3) Errores de monitorización (log)
 - [-] 4) Errores de configuración
 - [-] 7) Deficiencias en la organización
 - [-] 8) Difusión de software dañino
 - [-] 9) Errores de fre-juncamiento
 - [-] 10) Errores de secuencia
 - [-] 14) Fugas de información > 119)
 - [-] 15) Alteración de la información
 - [-] 18) Destrucción de la información
 - [-] 19) Fugas de información
 - [-] 20) Vulnerabilidades de los programas (software)
 - [-] 21) Errores de mantenimiento / actualización de programas (software)
 - [-] 23) Errores de mantenimiento / actualización de equipos (hardware)
 - [-] 24) Caída del sistema por agotamiento de recursos
 - [-] 25) Pérdida de equipos
 - [-] 26) Indisponibilidad del personal
 - [-] A) Ataques deliberados
 - [-] 19) Riesgos sobre la privacidad

activos

AMENAZAS

- [-] 1) Desastres naturales
- [-] 2) Daños por agua
- [-] 7) Desastres industriales
- [-] 13) Contaminación medioambiental
- [-] 14) Contaminación electromagnética
- [-] 5) Avería de origen físico o lógico
- [-] 6) Corte del suministro eléctrico
- [-] 7) Condiciones inadecuadas de temperatura o humedad
- [-] 8) Fallos de servicios de comunicaciones
- [-] 9) Interrupción de otros servicios o suministros esenciales
- [-] 10) Degradación de los soportes de almacenamiento de la información
- [-] 11) Emisiones electromagnéticas (TEMPEST)
- [-] Errores y fallos no intencionados
 - [-] 1) Errores de los usuarios
 - [-] 2) Errores del administrador del sistema / de la seguridad
 - [-] 3) Errores de monitorización (log)
 - [-] 4) Errores de configuración
 - [-] 7) Deficiencias en la organización
 - [-] 8) Difusión de software dañino
 - [-] 9) Errores de fre-juncamiento
 - [-] 10) Errores de secuencia
 - [-] 14) Fugas de información > 119)
 - [-] 15) Alteración de la información
 - [-] 18) Destrucción de la información
 - [-] 19) Fugas de información
 - [-] 20) Vulnerabilidades de los programas (software)
 - [-] 21) Errores de mantenimiento / actualización de programas (software)
 - [-] 23) Errores de mantenimiento / actualización de equipos (hardware)
 - [-] 24) Caída del sistema por agotamiento de recursos
 - [-] 25) Pérdida de equipos
 - [-] 26) Indisponibilidad del personal
 - [-] A) Ataques deliberados
 - [-] 19) Riesgos sobre la privacidad

amenazas

- [-] 15) Modificación de la información
- [-] 16) Destrucción de la información
- [-] 24) Denegación de servicio
- [+] Servicios internos
- [+] Equipamiento
- [+] Aplicaciones
- [+] Equipos
- [+] [Equipos] Puesto de trabajo
 - [-] 1) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres naturales
 - [-] 15) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres industriales
 - [-] 13) Contaminación medioambiental
 - [-] 14) Contaminación electromagnética
 - [-] 5) Avería de origen físico o lógico
 - [-] 6) Corte del suministro eléctrico
 - [-] 7) Condiciones inadecuadas de temperatura o humedad
 - [-] 8) Fallos de servicios de comunicaciones
 - [-] 9) Interrupción de otros servicios o suministros esenciales
 - [-] 10) Degradación de los soportes de almacenamiento de la información
 - [-] 11) Emisiones electromagnéticas (TEMPEST)
- [+] Errores y fallos no intencionados
 - [-] 1) Errores de los usuarios
 - [-] 2) Errores del administrador del sistema / de la seguridad
 - [-] 3) Errores de monitorización (log)
 - [-] 4) Errores de configuración
 - [-] 7) Deficiencias en la organización
 - [-] 8) Difusión de software dañino
 - [-] 9) Errores de fre-juncamiento
 - [-] 10) Errores de secuencia
 - [-] 14) Fugas de información > 119)
 - [-] 15) Alteración de la información
 - [-] 18) Destrucción de la información
 - [-] 19) Fugas de información
 - [-] 20) Vulnerabilidades de los programas (software)
 - [-] 21) Errores de mantenimiento / actualización de programas (software)
 - [-] 23) Errores de mantenimiento / actualización de equipos (hardware)
 - [-] 24) Caída del sistema por agotamiento de recursos
 - [-] 25) Pérdida de equipos
 - [-] 26) Indisponibilidad del personal
 - [-] A) Ataques deliberados
 - [-] 19) Riesgos sobre la privacidad

activos

AMENAZAS

- [-] 1) Desastres naturales
- [-] 2) Daños por agua
- [-] 7) Desastres industriales
- [-] 13) Contaminación medioambiental
- [-] 14) Contaminación electromagnética
- [-] 5) Avería de origen físico o lógico
- [-] 6) Corte del suministro eléctrico
- [-] 7) Condiciones inadecuadas de temperatura o humedad
- [-] 8) Fallos de servicios de comunicaciones
- [-] 9) Interrupción de otros servicios o suministros esenciales
- [-] 10) Degradación de los soportes de almacenamiento de la información
- [-] 11) Emisiones electromagnéticas (TEMPEST)
- [-] Errores y fallos no intencionados
 - [-] 1) Errores de los usuarios
 - [-] 2) Errores del administrador del sistema / de la seguridad
 - [-] 3) Errores de monitorización (log)
 - [-] 4) Errores de configuración
 - [-] 7) Deficiencias en la organización
 - [-] 8) Difusión de software dañino
 - [-] 9) Errores de fre-juncamiento
 - [-] 10) Errores de secuencia
 - [-] 14) Fugas de información > 119)
 - [-] 15) Alteración de la información
 - [-] 18) Destrucción de la información
 - [-] 19) Fugas de información
 - [-] 20) Vulnerabilidades de los programas (software)
 - [-] 21) Errores de mantenimiento / actualización de programas (software)
 - [-] 23) Errores de mantenimiento / actualización de equipos (hardware)
 - [-] 24) Caída del sistema por agotamiento de recursos
 - [-] 25) Pérdida de equipos
 - [-] 26) Indisponibilidad del personal
 - [-] A) Ataques deliberados
 - [-] 19) Riesgos sobre la privacidad

amenazas

- [-] 15) Modificación de la información
- [-] 16) Destrucción de la información
- [-] 24) Denegación de servicio
- [+] Servicios internos
- [+] Equipamiento
- [+] Aplicaciones
- [+] Equipos
- [+] [Equipos] Puesto de trabajo
 - [-] 1) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres naturales
 - [-] 15) Fuego
 - [-] 2) Daños por agua
 - [-] 7) Desastres industriales
 - [-] 13) Contaminación medioambiental
 - [-] 14) Contaminación electromagnética
 - [-] 5) Avería de origen físico o lógico
 - [-] 6) Corte del suministro eléctrico
 - [-] 7) Condiciones inadecuadas de temperatura o humedad
 - [-] 8) Fallos de servicios de comunicaciones
 - [-] 9) Interrupción de otros servicios o suministros esenciales
 - [-] 10) Degradación de los soportes de almacenamiento de la información
 - [-] 11) Emisiones electromagnéticas (TEMPEST)
- [+] Errores y fallos no intencionados
 - [-] 1) Errores de los usuarios
 - [-] 2) Errores del administrador del sistema / de la seguridad
 - [-] 3) Errores de monitorización (log)
 - [-] 4) Errores de configuración
 - [-] 7) Deficiencias en la organización
 - [-] 8) Difusión de software dañino
 - [-] 9) Errores de fre-juncamiento
 - [-] 10) Errores de secuencia
 - [-] 14) Fugas de información > 119)
 - [-] 15) Alteración de la información
 - [-] 18) Destrucción de la información
 - [-] 19) Fugas de información
 - [-] 20) Vulnerabilidades de los programas (software)
 - [-] 21) Errores de mantenimiento / actualización de programas (software)
 - [-] 23) Errores de mantenimiento / actualización de equipos (hardware)
 - [-] 24) Caída del sistema por agotamiento de recursos
 - [-] 25) Pérdida de equipos
 - [-] 26) Indisponibilidad del personal
 - [-] A) Ataques deliberados
 - [-] 19) Riesgos sobre la privacidad

activos

AMENAZAS

- [-] 1) Desastres naturales
- [-] 2) Daños por agua
- [-] 7) Desastres industriales
- [-] 13) Contaminación medioambiental
- [-] 14) Contaminación electromagnética
- [-] 5) Avería de origen físico o lógico
- [-] 6) Corte del suministro

Acceso a medidas y salvaguardas, muestro cada activo. Además, añado la recomendación:

- **Información**

aspe.	lsp	reco.	nivel		dudas	aplica	com...	cerr...	
SALVAGUARDAS									
G	EL	8		- [A] Identificación y autenticación			-L3	-L6	L2-L3
T	EL	7		- [AC] Control de acceso lógico			L2,L3	L2,L4	L2-L3
G	PR	8		- [E] Protección de la información			L2	L4	L2-L3
G	EL			- [K] Protección de claves criptográficas [EC-12]			L2	L2,L5	L2-L3
G	PR			- [S] Protección de los Servicios					N.d.
G	PR			- [SWI] Protección de las Aplicaciones Informáticas (SW)					N.d.
G	PR			- [HWI] Protección de los Equipos Informáticos (HW)					N.d.
G	PR			- [COM] Protección de las Comunicaciones					N.d.
G	PR			- [M] Protección de los Soportes de Información					N.d.
G	PR			- [ADG] Elementos Auxiliares					N.d.
F	EL			- [PPE] Protección física de los equipos					N.d.
F	PR			- [LI] Protección de las instalaciones					N.d.
P	PR			- [O] Gestión del Personal					N.d.
G	CR	5		- [MI] Gestión de incidentes					N.d.
T	PR	5		- [Tools] Herramientas de seguridad			L2	L2,L3	L2-L3
G	CR			- [V] Gestión de vulnerabilidades			L2	L2,L3	L2-L3
T	MN	4		- [R] Registro y auditoría			L2	L2,L3	L2-L3
G	RC			- [BC] Continuidad del negocio			L2	L2,L3	L2-L3
G	AO	4		- [OG] Organización			L2	L2,L3	L2-L3
G	AO	3		- [RE] Relaciones Externas			L2	L2,L3	L2-L3
G	AO	2		- [NEW] Adquisición / desarrollo			L2	L2	L2-L3
G	PR			- [POS] Servicios potencialmente peligrosos					N.d.
G	PR			- [PSI] Sistema de protección de frontera lógica					N.d.
F	EL			- [PPS] Protección del perímetro físico					N.d.
G	EL			- [TEMPEST] Protección de emanaciones (TEMPEST) [EP-19]					N.d.

Alberto Dieguez Alvarez

[Editar perfil]

Información Personal

Dirección de correo:
a.dieguez.alvarez@gmail.com

Detalles del curso
Perfiles de curso
 Análisis Forense Informático (25-26)
 Bastionado de Redes y Sistemas (25-26)
 Hacking Ético (25-26)
 Incidentes de Ciberseguridad (25-26)
 Normativa de ciberseguridad (25-26)

Actividad de accesos
Primer acceso al sitio
 miércoles, 13 de noviembre de 2024,
 15:15 (1 año 31 días)

Último acceso al sitio
 lunes, 15 de diciembre de 2025, 10:13 (1 minutos)

- **Servicio**

[illegible]

- **Equipamiento:**

P [2024SD] A.S. Medidas > A.S.1. Salvaguardas

Editar Expandir Ver Exportar Importar Estadísticas

[Equipamiento] activo de equipamiento informático						
sape.	idp	reco.	nivel	salvaguarda	dónde aplica	com...
G	EL			SALVAGUARDAS		
G	EL			(A) Identificación y autenticación		L2 L3 L4
T	EL			(AC) Control de acceso lógico		n.a.
G	PR			(PI) Protección de la Información		n.a.
G	PR			(K) Protección de claves criptográficas (SC-12)		n.a.
G	PR			(SI) Protección de los Servicios		n.a.
G	PR			(SWI) Protección de las Aplicaciones Informáticas (SWI)		n.a.
G	PR	4		(SHVI) Protección de los Equipos Informáticos (HW)		L2 L3 L4
G	PR			(COM) Protección de las Comunicaciones		n.a.
G	PR			(M) Protección de los Soportes de Información		n.a.
G	PR	3		(AUO) Elementos Auxiliares		L2 L3 L4
F	EL	5		(PPE) Protección física de los equipos		L2 L3 L4
F	PR			(LI) Protección de las Instalaciones		L2 L3 L4
F	PR			(G) Gestión del Personal		n.a.
G	CR	4		(MI) Gestión de incidentes		L2 L3 L4
T	PR	3		(HSA) Herramientas de seguridad		L2 L3 L4
G	CR			(GV) Gestión de vulnerabilidades		n.a.
T	MN	4		(AR) Registro y auditoría		L2 L3 L4
G	AD	1 (o)		(BC) Continuidad del negocio		L2 L2 L2
G	AD	3		(OG) Organización		L2 L3 L4
G	AD	3		(RE) Relaciones Externas		L2 L3 L4
G	AD	3		(DEVI) Adquisición / desarrollo		L2 L3 L4
G	PR			(PDG) Servicios potencialmente peligrosos		n.a.
G	PR			(PS) Sistema de protección de frontera lógica		n.a.
F	EL			(PPS) Protección del perímetro físico		n.a.
G	EL	1 (o)		(TEMPEST) Protección de emanaciones (TEMPEST) (PE-19)		L2 L2 L2

ALBERTO DIEGUEZ ALVAREZ

[?] Editar perfil

Información Personal

Dirección de correo:
a.dieguez.alvarez@gmail.com

Detalles del curso

Perfiles de curso

- Análisis Forense
- Informático (25-26)
- Bastionado de Redes y Sistemas (25-26)
- Hacking Ético (25-26)
- Incidentes de Ciberseguridad (25-26)
- Normativa de Ciberseguridad (25-26)

Primer acceso al sitio
miércoles, 13 de noviembre de 2024,
15:15 (1 año 31 días)

Último acceso al sitio
lunes, 15 de diciembre de 2025, 10:13 (1 minutos)

- **Comunicación:**

The screenshot displays the 'Comunicación' section of the P[205AD] A.S. Medidas > A.S.1. Salvaguardas application. The main table lists various communication measures (salvaguardas) with columns for 'aspe.', 'tdp', 'reco.', 'nivel', 'salvaguarda', 'dudas', 'aplica', 'com.', 'curr.', and 'n.a.'. The measures include identification and authentication, access control, information protection, cryptographic key protection, service protection, application information protection, equipment information protection, communication protection, support information protection, auxiliary elements, physical equipment protection, installation protection, personal management, incident management, security tools, vulnerability management, registration and audit, business continuity, organization, external relations, and potentially dangerous services. A secondary table at the bottom shows 'por dominios' with columns for 'dominio de seguridad', 'IA', 'AC', 'D', 'K', 'S', 'SW', 'RW', 'COM', 'M', 'AUX', 'PPE', 'L', 'R', 'NM', 'tools', 'V', 'A', 'BC', 'G', 'E', 'NEW', 'POS', 'IR', 'PPS', 'TEMPEST', and 'Total'. The 'Total' column shows values for each measure, such as 2035 for 'Información activo esencial de información' and 14 for 'Comunicación activo de redes de comunicación'.

On the right side, the user profile for **ALBERTO DIEGUEZ ALVAREZ** is visible. It includes a profile picture, a 'Editar perfil' button, and personal information: 'Dirección de correo: a.dieguez.alvarez@gmail.com'. Below this, there are sections for 'Detalles del curso' (Perfiles de curso: Análisis Forense Informático (25-26), Bastionado de Redes y Sistemas (25-26), Hacking Ético (25-26), Incidentes de Ciberseguridad (25-26), Normativa de Ciberseguridad (25-26)) and 'Actividad de accesos' (Primer acceso al sitio: miércoles, 13 de noviembre de 2024, 15:15 (1 año 31 días); Último acceso al sitio: lunes, 15 de diciembre de 2025, 10:13 (1 minutos)).

Muestro también las estadísticas.

This screenshot is similar to the previous one, showing the same application interface. However, the 'por dominios' table at the bottom is more prominent, showing the following data:

dominio de seguridad	IA	AC	D	K	S	SW	RW	COM	M	AUX	PPE	L	R	NM	tools	V	A	BC	G	E	NEW	POS	IR	PPS	TEMPEST	Total	
[base] Red de empresa															204	129	198	346	32	202						2035	
[Información] activo esencial de información	342	274	308												212	208	198	366	54	392						2410	
[Servicio] activo esencial de servicio	234	274		472											212	208	198	138	366	54	392					14	2134
[Equipamiento] activo de equipamiento informático						440			90	22					206	112	198	138	348	62	225					1580	
[Comunicación] activo de redes de comunicación					303																					14	
TOTAL	576	548	308	0	775	0	440	0	90	22	0	0	834	657	792	276	1424	192	1211	0	0	0	0	0	14	8159	

Apartado 4: Estimación del riesgo que tendría que considerar la empresa para su estudio y toma de decisiones.

Deberás efectuar la siguiente tarea:

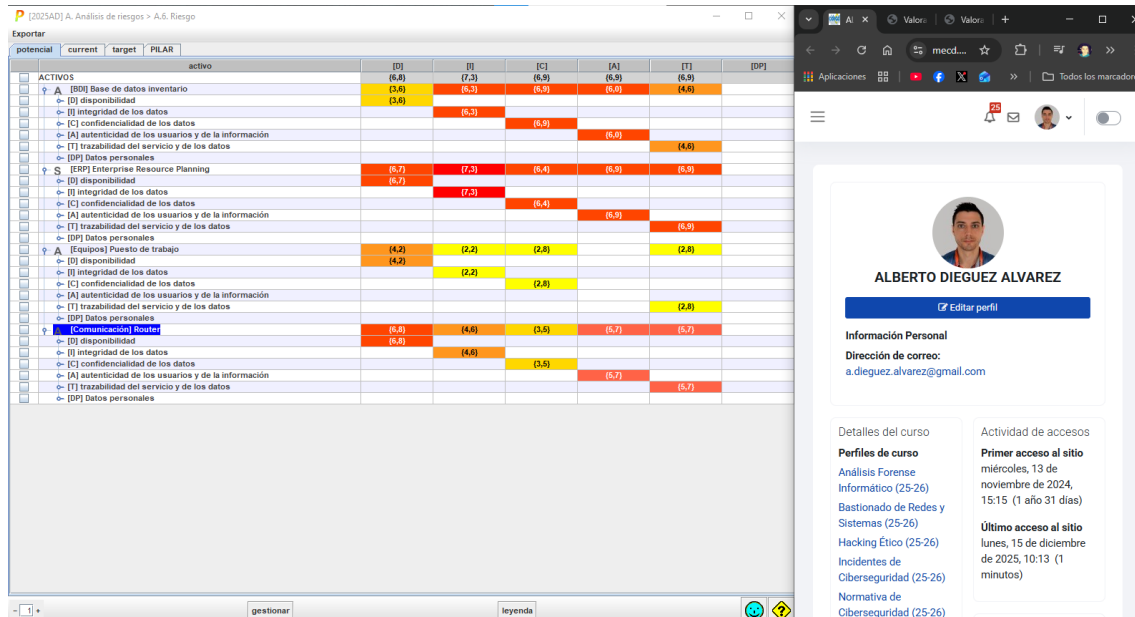
- Para cada uno de los cuatro activos seleccionados en el apartado uno, indica la estimación del estado del riesgo a asumir por la empresa. Se debe indicar la estimación actual (current) y la estimación objetivo

(target).

Calcula la bajada que se produce en los riesgos en cada uno de los criterios de seguridad para cada activo.

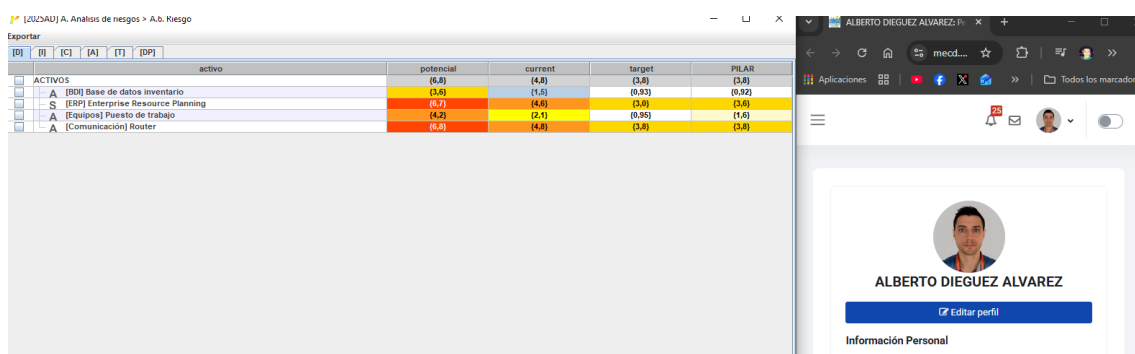
Además, muestra una captura de la gráfica de riesgos de tipo "Área" en la que se muestran los cuatro activos con sus valores actuales, objetivo y recomendados por PILAR.

Analizo los riesgos.



Si las analizamos una por una tenemos lo siguiente.

- **Disponibilidad:**



- Base de datos inventario: Una bajada de **0,57**
- Enterprise Resource Planning: Una bajada de **1,6**
- Puestos de trabajo: Una bajada de **1,15**
- Router: Una bajada de **1**

• Integridad:

[2025AD] A. Análisis de riesgos > A.6. Riesgo

Exportar

	activo	potencial	current	target	PIE.A.R
ACTIVOS		(7,3)	(5,2)	(3,3)	(4,2)
A [BDI] Base de datos inventario		(6,3)	(4,2)	(2,8)	(3,1)
S [ERP] Enterprise Resource Planning		(7,2)	(5,2)	(3,2)	(4,2)
A [Equipos] Puesto de trabajo		(2,2)	(0,41)	(0,56)	(0,71)
A [Comunicación] Router		(4,6)	(2,6)	(1,7)	(1,7)

ALBERTO DIEGUEZ ALVAREZ

Editar perfil

Información Personal

Dirección de correo: a.dieguez.alvarez@gmail.com

- Base de datos inventario: Una bajada de **1,4**
- Enterprise Resource Planning: Una bajada de **1,9**
- Puestos de trabajo: Una bajada de **0,31**
- Router: Una bajada de **0,9**

• Confidencialidad:

[2025AD] A. Análisis de riesgos > A.6. Riesgo

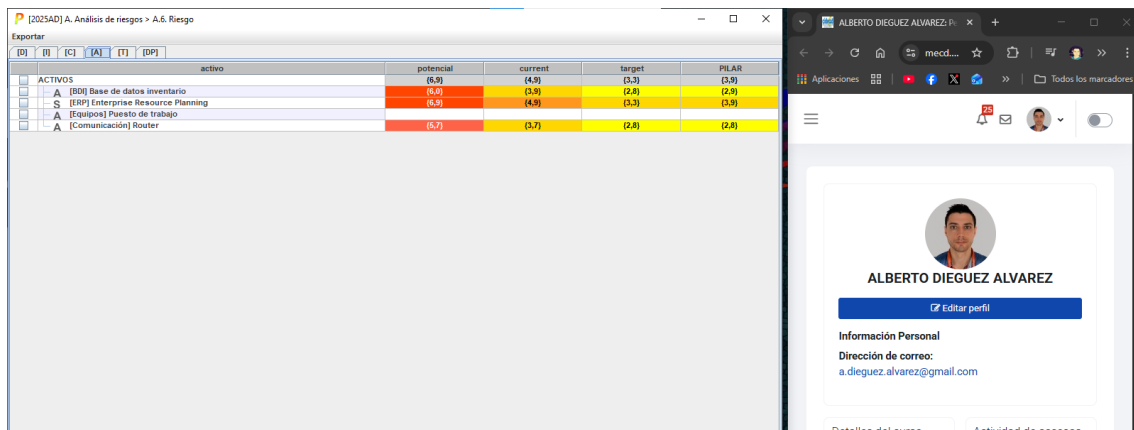
Exportar

	activo	potencial	current	target	PIE.A.R
ACTIVOS		(6,9)	(4,8)	(3,6)	(3,8)
A [BDI] Base de datos inventario		(6,9)	(4,8)	(3,6)	(3,8)
S [ERP] Enterprise Resource Planning		(5,4)	(4,3)	(2,8)	(3,4)
A [Equipos] Puesto de trabajo		(2,4)	(0,54)	(0,63)	(0,84)
A [Comunicación] Router		(3,5)	(1,4)	(0,96)	(0,96)

ALBERTO DIEGUEZ ALVAREZ

- Base de datos inventario: Una bajada de **1,3**
- Enterprise Resource Planning: Una bajada de **1,7**
- Puestos de trabajo: Una bajada de **0,31**
- Router: Una bajada de **0,5**

• Autenticidad:

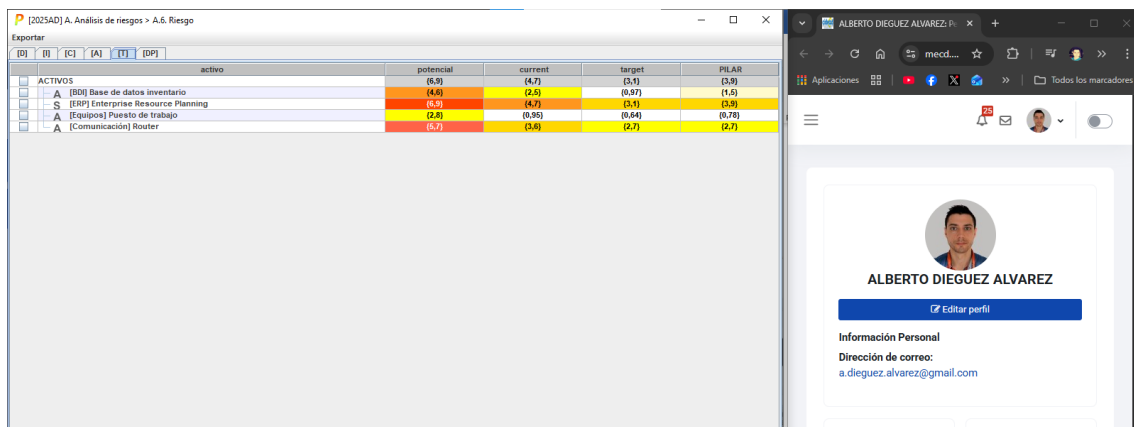


The image shows two side-by-side screenshots. The left screenshot is from a risk analysis tool titled "[2025AD] A. Analisis de riesgos > A.6. Riesgo". It displays a table with columns: activo, potencial, current, target, and PILAR. The right screenshot is a user profile page for "ALBERTO DIEGUEZ ALVAREZ" with a profile picture and a blue "Editar perfil" button. Below the name, it says "Información Personal" and "Dirección de correo: a.dieguez.alvarez@gmail.com".

activo	potencial	current	target	PILAR
ACTIVOS	(5,9)	(4,9)	(3,3)	(3,9)
A [BDI] Base de datos inventario	(5,9)	(4,9)	(3,3)	(3,9)
S [ERP] Enterprise Resource Planning	(5,9)	(4,9)	(3,3)	(3,9)
A [Equipos] Puesto de trabajo	(5,9)	(4,9)	(3,3)	(3,9)
A [Comunicación] Router	(5,9)	(4,9)	(3,3)	(3,9)

- Base de datos inventario: Una bajada de **1,1**
- Enterprise Resource Planning: Una bajada de **1,6**
- Puestos de trabajo: -
- Router: Una bajada de **0,9**

• Trazabilidad:



The image shows two side-by-side screenshots. The left screenshot is from a risk analysis tool titled "[2025AD] A. Analisis de riesgos > A.6. Riesgo". It displays a table with columns: activo, potencial, current, target, and PILAR. The right screenshot is a user profile page for "ALBERTO DIEGUEZ ALVAREZ" with a profile picture and a blue "Editar perfil" button. Below the name, it says "Información Personal" and "Dirección de correo: a.dieguez.alvarez@gmail.com".

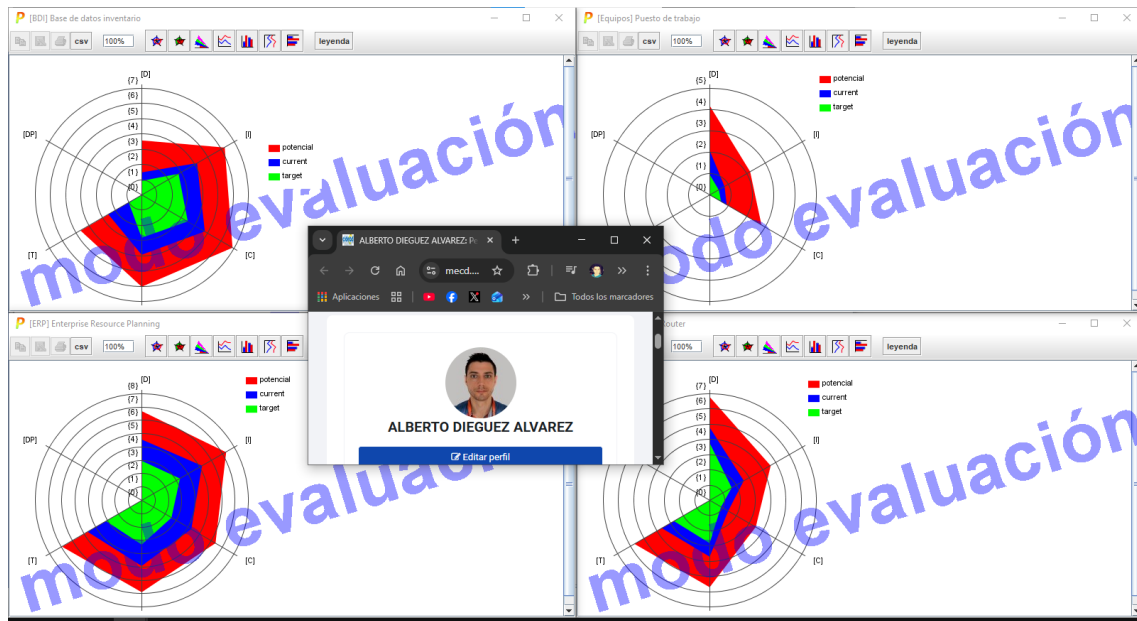
activo	potencial	current	target	PILAR
ACTIVOS	(4,7)	(2,5)	(0,97)	(1,5)
A [BDI] Base de datos inventario	(4,7)	(2,5)	(0,97)	(1,5)
S [ERP] Enterprise Resource Planning	(4,7)	(2,5)	(0,97)	(1,5)
A [Equipos] Puesto de trabajo	(4,7)	(2,5)	(0,97)	(1,5)
A [Comunicación] Router	(4,7)	(2,5)	(0,97)	(1,5)

- Base de datos inventario: Una bajada de **1,53**
- Enterprise Resource Planning: Una bajada de **1,6**
- Puestos de trabajo: Una bajada de **0,31**
- Router: Una bajada de **0,9**

• Datos personales.

No aplica.

Ahora muestro los gráficos de tipo área con el valor actual, el objetivo y el recomendado por PILAR, adjunto los 4 juntos.



Apartado 5: Taxonomía de incidentes.

Deberás efectuar la siguiente tarea:

- Para cada uno de los cuatro activos seleccionados en el apartado uno y tras el estudio de sus riesgos, determina un tipo de incidente que podría producirse en relación a sus riesgos. Para este tipo de incidente indica el grupo al que pertenece y realiza una pequeña explicación sobre este.
- **Base de datos inventario:**
 - **Riesgo:** E.18.1. Destrucción de la información.
 - **Tipo de incidente:** Corrupción de datos.
 - **Grupo:** Integridad
 - **Explicación:** Un error en el software de la base de datos, o un fallo físico, puede destruir los datos.
- **ERP:**
 - **Riesgo:** E.20. Vulnerabilidad de los programas.
 - **Tipo de incidente:** Explotación de alguna vulnerabilidad.
 - **Grupo:** Vulnerabilidad
 - **Explicación:** Si no se actualiza o se aplican parches de seguridad en el ERP, un atacante podría explotar alguna vulnerabilidad no parcheada.

- **Puestos de trabajo:**
 - **Riesgo:** A.25. Robo de equipos.
 - **Tipo de incidente:** Robo de equipo
 - **Grupo:** Confidencialidad
 - **Explicación:** Sí se produjese un robo de un ordenador, el atacante podría tener acceso a la información.

- **Router:**
 - **Riesgo:** I.6.x. Cortes eléctricos.
 - **Tipo de incidente:** Corte en el servicio de red
 - **Grupo:** Disponibilidad
 - **Explicación:** Cualquier tipo de corte en el suministro eléctrico en el **Router**, provocaría una pérdida del servicio de internet.

Notas:

Algunas partes de la tarea se me hicieron confusas, como la asignación de valor en las salvaguardas, es como que no recomendaba bien.

He buscado información en las siguientes webs:

- https://www.pilar-tools.com/doc/v2025/pilar_basic/help_es/Valoracionpordominios.html
- <https://www.youtube.com/watch?v=TNnIAMJzIW4>
- <https://www.um.es/docencia/barzana/GESESI/GuiaPilar.pdf>